

PROYECTO FINAL DE CIBERSEGURIDAD



Analista de seguridad: Yulybeth Rios

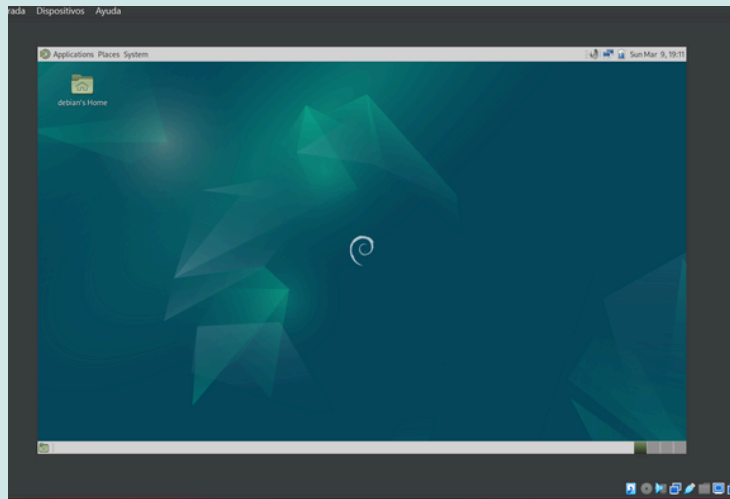
Marzo, 2025

UN SERVIDOR CRÍTICO FUÉ COMPROMETIDO

Objetivo buscar hackeo y otras vulnerabilidades en la máquina. Para que así cumpla con los principios disponibilidad, confidencialidad e integridad.

Análisis Forense

- Escaneo de puertos y servicios con NMAP



```
kali@kali: ~  
File Actions Edit View Help  
  
(kali@kali)-[~]  
$ nmap -sS -sV -O -p- 192.168.1.48  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-26 21:18 EST  
Nmap scan report for 192.168.1.48  
Host is up (0.0015s latency).  
Not shown: 65532 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
21/tcp    open  ftp      vsftpd 3.0.3  
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)  
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))  
MAC Address: 08:00:27:54:10:26 (Oracle VirtualBox virtual NIC)  
Device type: general purpose  
Running: Linux 4.X|5.X  
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5  
OS details: Linux 4.15 - 5.8  
Network Distance: 1 hop  
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.  
Nmap done: 1 IP address (1 host up) scanned in 37.56 seconds  
  
(kali@kali)-[~]  
$
```


Análisis Forense

- Revisando configuración apache

```
kali-linux-2024.4-virtualbox-amd64 [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

File  Actions  Edit  View  Help
LogFormat "%{User-agent}i" agent

# Include of directories ignores editors' and dpkg's backup files,
# see README.Debian for details.

# Include generic snippets of statements
IncludeOptional conf-enabled/*.conf

# Include the virtual host configurations:
IncludeOptional sites-enabled/*.conf
root@debian:/etc/apache2# grep -E "(Allow|Deny|Options|LoadModule|PHPversion|
ServerSignature|Timeout|KeepAlive)" /etc/apache2/apache2.conf
# Timeout: The number of seconds before receives and sends time out.
Timeout 300
# KeepAlive: Whether or not to allow persistent connections (more than
KeepAlive On
# MaxKeepAliveRequests: The maximum number of requests to allow
MaxKeepAliveRequests 100
# KeepAliveTimeout: Number of seconds to wait for the next request from the
KeepAliveTimeout 5
    Options Indexes FollowSymLinks
    AllowOverride None
    AllowOverride None
    Options Indexes FollowSymLinks
    Options Indexes FollowSymLinks
    AllowOverride None
#    Options Indexes FollowSymLinks
#    AllowOverride None
# for additional configuration directives. See also the AllowOverride
root@debian:/etc/apache2#
```

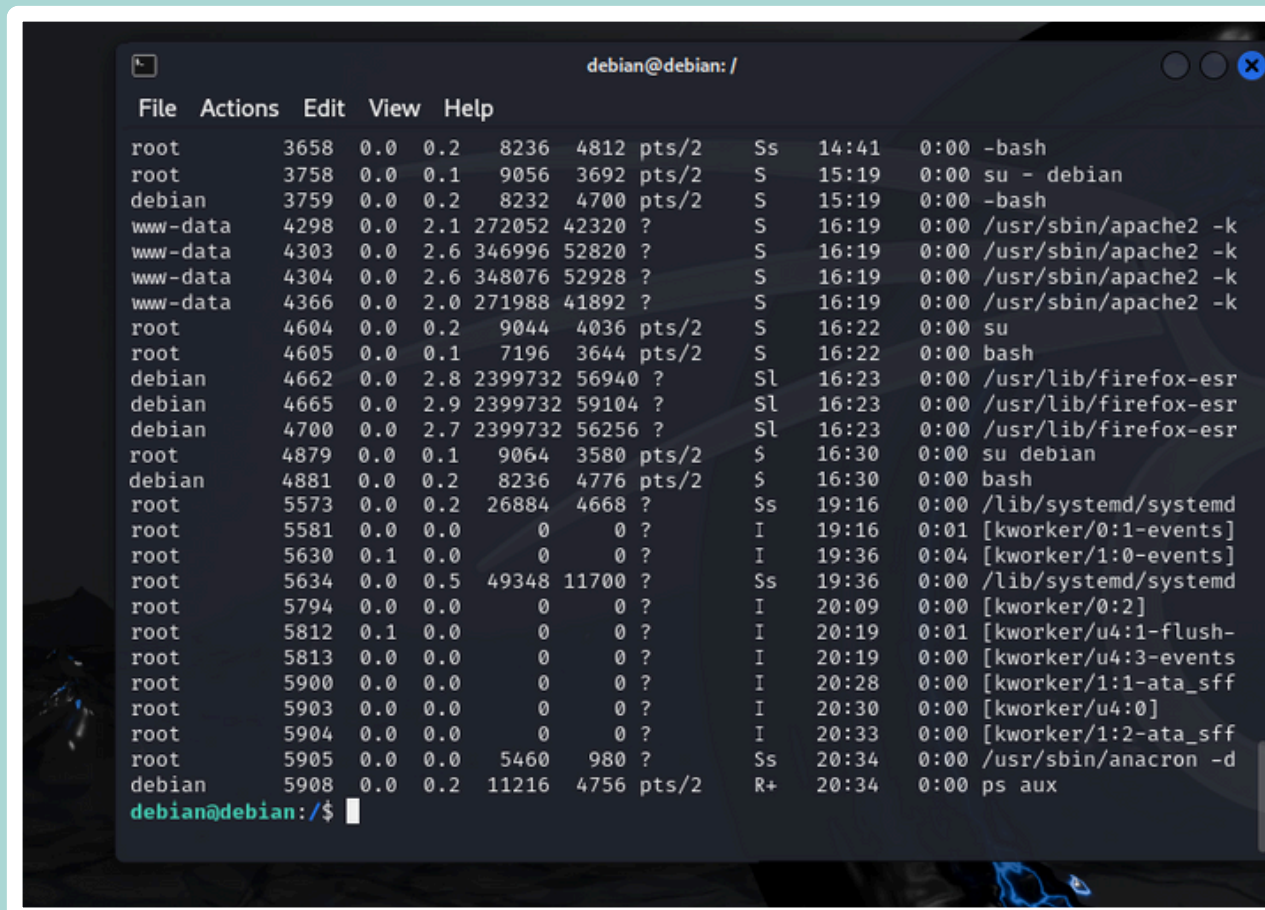
- Revisando log SSH con Journalctl

```
24.4-virtualbox-amd64 [Corriendo] - Oracle VirtualBox
Máquina  Ver  Entrada  Dispositivos  Ayuda

File  Actions  Edit  View  Help
Oct 08 16:14:16 debian sshd[560]: Received signal 15; terminating.
Oct 08 16:14:16 debian systemd[1]: ssh.service: Deactivated successfully.
Oct 08 16:14:16 debian systemd[1]: Stopped ssh.service - OpenBSD Secure Shell server.
Oct 08 16:14:16 debian systemd[1]: Starting ssh.service - OpenBSD Secure Shell server.
Oct 08 16:14:16 debian sshd[5341]: Server listening on 0.0.0.0 port 22.
Oct 08 16:14:16 debian sshd[5341]: Server listening on :: port 22.
Oct 08 16:14:16 debian systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
-- Boot 342683d8f35244b08c4f3863f2978eca --
Oct 08 16:43:18 debian systemd[1]: Starting ssh.service - OpenBSD Secure Shell server.
Oct 08 16:43:18 debian sshd[543]: Server listening on 0.0.0.0 port 22.
Oct 08 16:43:18 debian sshd[543]: Server listening on :: port 22.
Oct 08 16:43:18 debian systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
-- Boot d28e179bf5884b25bf94452c79fd0afa --
Oct 08 16:48:02 debian systemd[1]: Starting ssh.service - OpenBSD Secure Shell server.
Oct 08 16:48:02 debian sshd[555]: Server listening on 0.0.0.0 port 22.
Oct 08 16:48:02 debian sshd[555]: Server listening on :: port 22.
Oct 08 16:48:02 debian systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
-- Boot af0a79f76920440c8e08594d6547449b --
Oct 08 17:28:37 debian systemd[1]: Starting ssh.service - OpenBSD Secure Shell server.
Oct 08 17:28:38 debian sshd[550]: Server listening on 0.0.0.0 port 22.
Oct 08 17:28:38 debian sshd[550]: Server listening on :: port 22.
Oct 08 17:40:59 debian systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
Oct 08 17:40:59 debian sshd[1650]: Accepted password for root from 192.168.0.134 port 22.
Oct 08 17:40:59 debian sshd[1650]: pam_unix(sshd:session): session opened for user root
Oct 08 17:40:59 debian sshd[1650]: pam_env(sshd:session): deprecated reading of user e
-- Boot 7cc07c37204c4c649e1880a444c9bb9a --
lines 15-40
```

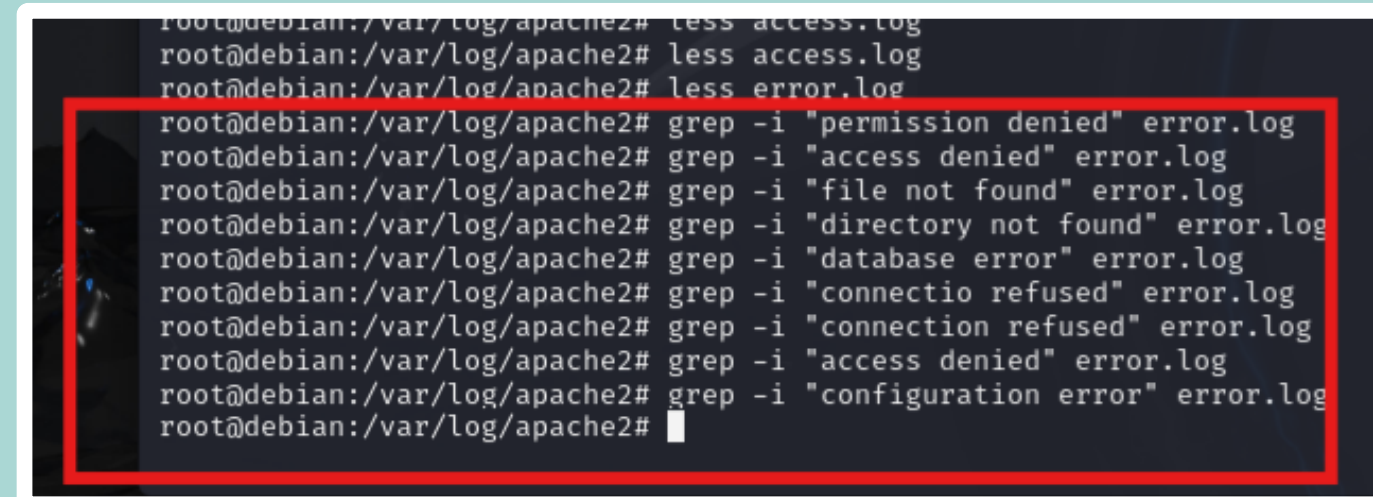
Análisis Forense

- Revisando procesos en ejecución



```
debian@debian: /  
File Actions Edit View Help  
root      3658  0.0  0.2  8236  4812 pts/2    Ss   14:41   0:00 -bash  
root      3758  0.0  0.1  9056  3692 pts/2    S    15:19   0:00 su - debian  
debian    3759  0.0  0.2  8232  4700 pts/2    S    15:19   0:00 -bash  
www-data  4298  0.0  2.1 272052 42320 ?        S    16:19   0:00 /usr/sbin/apache2 -k  
www-data  4303  0.0  2.6 346996 52820 ?        S    16:19   0:00 /usr/sbin/apache2 -k  
www-data  4304  0.0  2.6 348076 52928 ?        S    16:19   0:00 /usr/sbin/apache2 -k  
www-data  4366  0.0  2.0 271988 41892 ?        S    16:19   0:00 /usr/sbin/apache2 -k  
root      4604  0.0  0.2   9044   4036 pts/2    S    16:22   0:00 su  
root      4605  0.0  0.1   7196   3644 pts/2    S    16:22   0:00 bash  
debian    4662  0.0  2.8 2399732 56940 ?        Sl   16:23   0:00 /usr/lib/firefox-esr  
debian    4665  0.0  2.9 2399732 59104 ?        Sl   16:23   0:00 /usr/lib/firefox-esr  
debian    4700  0.0  2.7 2399732 56256 ?        Sl   16:23   0:00 /usr/lib/firefox-esr  
root      4879  0.0  0.1   9064   3580 pts/2    S    16:30   0:00 su debian  
debian    4881  0.0  0.2   8236   4776 pts/2    S    16:30   0:00 bash  
root      5573  0.0  0.2  26884   4668 ?        Ss   19:16   0:00 /lib/systemd/systemd  
root      5581  0.0  0.0         0         0 ?        I    19:16   0:01 [kworker/0:1-events]  
root      5630  0.1  0.0         0         0 ?        I    19:36   0:04 [kworker/1:0-events]  
root      5634  0.0  0.5  49348 11700 ?        Ss   19:36   0:00 /lib/systemd/systemd  
root      5794  0.0  0.0         0         0 ?        I    20:09   0:00 [kworker/0:2]  
root      5812  0.1  0.0         0         0 ?        I    20:19   0:01 [kworker/u4:1-flush-  
root      5813  0.0  0.0         0         0 ?        I    20:19   0:00 [kworker/u4:3-events]  
root      5900  0.0  0.0         0         0 ?        I    20:28   0:00 [kworker/1:1-ata_sff  
root      5903  0.0  0.0         0         0 ?        I    20:30   0:00 [kworker/u4:0]  
root      5904  0.0  0.0         0         0 ?        I    20:33   0:00 [kworker/1:2-ata_sff  
root      5905  0.0  0.0   5460    980 ?        Ss   20:34   0:00 /usr/sbin/anacron -d  
debian    5908  0.0  0.2  11216  4756 pts/2    R+   20:34   0:00 ps aux  
debian@debian:/$
```

- Buscando patrones específicos con GREP



```
root@debian:/var/log/apache2# less access.log  
root@debian:/var/log/apache2# less error.log  
root@debian:/var/log/apache2# grep -i "permission denied" error.log  
root@debian:/var/log/apache2# grep -i "access denied" error.log  
root@debian:/var/log/apache2# grep -i "file not found" error.log  
root@debian:/var/log/apache2# grep -i "directory not found" error.log  
root@debian:/var/log/apache2# grep -i "database error" error.log  
root@debian:/var/log/apache2# grep -i "connection refused" error.log  
root@debian:/var/log/apache2# grep -i "connection refused" error.log  
root@debian:/var/log/apache2# grep -i "access denied" error.log  
root@debian:/var/log/apache2# grep -i "configuration error" error.log  
root@debian:/var/log/apache2#
```


Análisis Forense

- Revisando configuración del directorio raíz de wordpress

- Verificación usuario en base de datos

```
</html>
debian@debian:/var/www/html$ ls -l
total 248
-rwxrwxrwx 1 www-data www-data 10701 Sep 30 10:44 index.html
-rwxrwxrwx 1 www-data www-data 405 Feb 6 2020 index.php
-rwxrwxrwx 1 www-data www-data 19915 Feb 21 10:51 license.txt
-rwxrwxrwx 1 www-data www-data 7409 Feb 21 10:51 readme.html
-rwxrwxrwx 1 www-data www-data 7387 Feb 13 2024 wp-activate.php
drwxrwxrwx 9 www-data www-data 4096 Sep 10 11:23 wp-admin
-rwxrwxrwx 1 www-data www-data 351 Feb 6 2020 wp-blog-header.php
-rwxrwxrwx 1 www-data www-data 2323 Jun 14 2023 wp-comments-post.php
-rwxrwxrwx 1 www-data www-data 3017 Sep 30 12:02 wp-config.php
-rwxrwxrwx 1 www-data www-data 3336 Feb 21 10:51 wp-config-sample.php
drwxrwxrwx 6 www-data www-data 4096 Feb 21 22:27 wp-content
-rwxrwxrwx 1 www-data www-data 5617 Feb 21 10:51 wp-cron.php
drwxrwxrwx 30 www-data www-data 12288 Feb 21 10:51 wp-includes
-rwxrwxrwx 1 www-data www-data 2502 Nov 26 2022 wp-links-opml.php
-rwxrwxrwx 1 www-data www-data 3937 Mar 11 2024 wp-load.php
-rwxrwxrwx 1 www-data www-data 51367 Feb 21 10:51 wp-login.php
-rwxrwxrwx 1 www-data www-data 8543 Feb 21 10:51 wp-mail.php
-rwxrwxrwx 1 www-data www-data 29032 Feb 21 10:51 wp-settings.php
-rwxrwxrwx 1 www-data www-data 34385 Jun 19 2023 wp-signup.php
-rwxrwxrwx 1 www-data www-data 5102 Feb 21 10:51 wp-trackback.php
-rwxrwxrwx 1 www-data www-data 3246 Mar 2 2024 xmlrpc.php
debian@debian:/var/www/html$
```

```
-rwxrwxrwx 1 www-data www-data 3246 Mar 2 2024 xmlrpc.php
debian@debian:/var/www/html$ sudo mysql -u root -p
[sudo] password for debian:
Enter password:
Welcome to the MariaDB monitor. Commands end with ; or \g.
Your MariaDB connection id is 143
Server version: 10.11.6-MariaDB-0+deb12u1 Debian 12

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> SELECT User FROM mysql.user;
+-----+
| User          |
+-----+
| mariadb.sys   |
| mysql         |
| root          |
| user          |
| wordpressuser |
+-----+
5 rows in set (0.045 sec)

MariaDB [(none)]>
```

Análisis Forense

```
MariaDB [(none)]> SHOW GRANTS FOR 'user'@'localhost';  
+-----+  
| Grants for user@localhost |  
+-----+  
| GRANT ALL PRIVILEGES ON *.* TO `user`@`localhost` IDENTIFIED BY PASSWORD '*2470C0C06D  
EE42FD1618BB99005ADCA2EC9D1E19' WITH GRANT OPTION |  
+-----+  
1 row in set (0.010 sec)  
  
MariaDB [(none)]> █
```

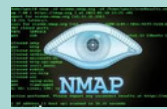
```
MariaDB [(none)]> SHOW GRANTS FOR 'wordpressuser'@'localhost';  
+-----+  
| Grants for wordpressuser@localhost |  
+-----+  
| GRANT USAGE ON *.* TO `wordpressuser`@`localhost` IDENTIFIED BY PASSWORD '*6BB4837EB7  
4329105EE4568DDA7DC67ED2CA2AD9' |  
| GRANT ALL PRIVILEGES ON `wordpress`.* TO `wordpressuser`@`localhost` |  
+-----+  
2 rows in set (0.000 sec)  
  
MariaDB [(none)]> █
```

```
2 rows in set (0.001 sec)  
  
MariaDB [(none)]> SHOW GRANTS FOR 'root'@'localhost';  
+-----+  
| Grants for root@localhost |  
+-----+  
| GRANT ALL PRIVILEGES ON *.* TO `root`@`localhost` IDENTIFIED VIA mysql_native_password  
USING '*6BB4837EB74329105EE4568DDA7DC67ED2CA2AD9' OR unix_socket WITH GRANT OPTION |  
| GRANT PROXY ON ''@'%' TO 'root'@'localhost' WITH GRANT OPTION |  
+-----+  
+-----+  
+-----+
```


Detección y explotación de vulnerabilidades

Se usó herramientas como:

- Chkrootkit
- Rkhunter
- Nmap
- Jonh the Ripper



- Con Rkhunter generó advertencias

```
debian@debian: /  
File Actions Edit View Help  
Checking for system startup files [ Found ]  
Checking system startup files for malware [ None found ]  
  
Performing group and account checks  
Checking for passwd file [ Found ]  
Checking for root equivalent (UID 0) accounts [ None found ]  
Checking for passwordless accounts [ None found ]  
Checking for passwd file changes [ None found ]  
Checking for group file changes [ None found ]  
Checking root account shell history files [ OK ]  
  
Performing system configuration file checks  
Checking for an SSH configuration file [ Found ]  
Checking if SSH root access is allowed [ Warning ]  
Checking if SSH protocol v1 is allowed [ Not set ]  
Checking for other suspicious configuration settings [ None found ]  
Checking for a running system logging daemon [ Found ]  
Checking for a system logging configuration file [ Found ]  
  
Performing filesystem checks  
Checking /dev for suspicious file types [ None found ]  
Checking for hidden files and directories [ None found ]  
  
[Press <ENTER> to continue]
```

```
# Authentication:
```

```
#LoginGraceTime 2m
```

```
PermitRootLogin yes
```

```
#StrictModes yes
```

```
#MaxAuthTries 6
```

Detección y explotación de vulnerabilidades

- Con NMAP se realizó un escaneo más profundo de vulnerabilidades.

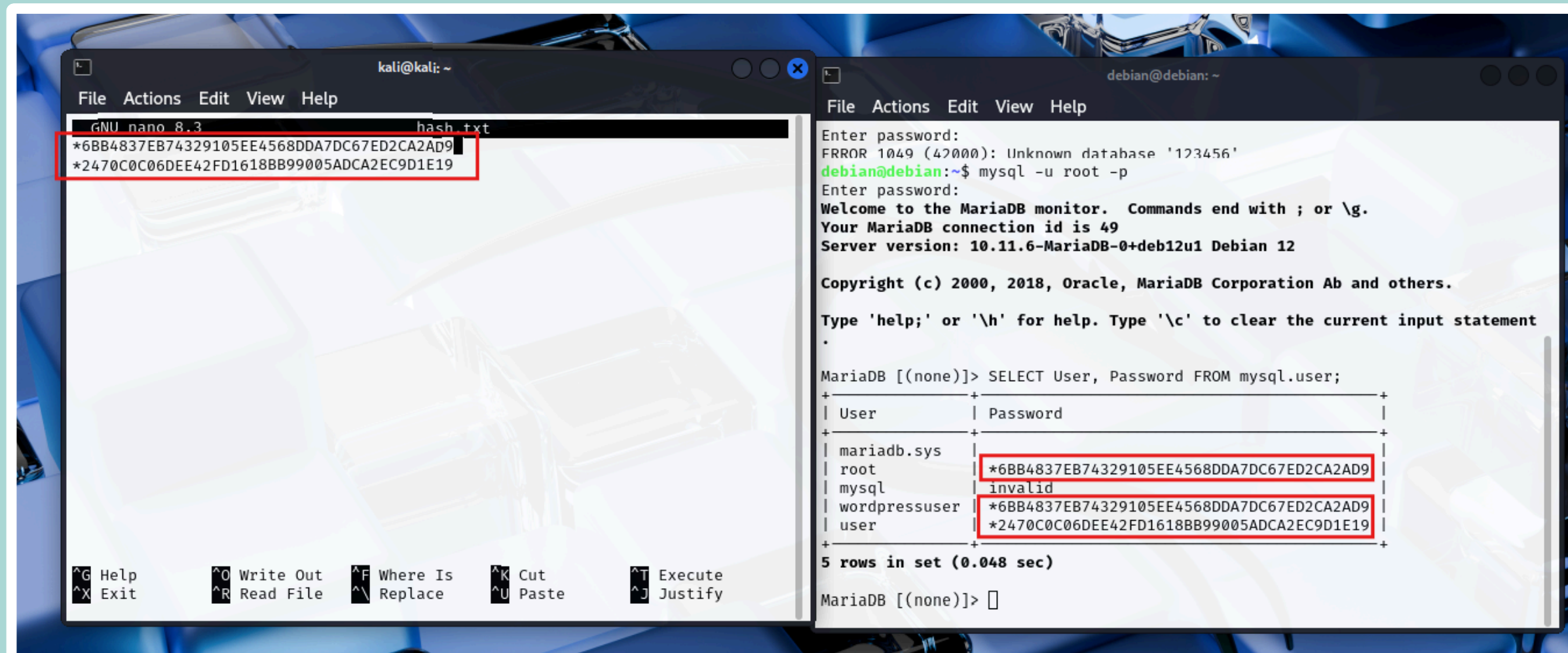
```
File Actions Edit View Help
kali@kali: ~
$ sudo nmap -sV --script vuln,default,ssl-enum-ciphers,smb-vuln-* -p- 192.168.1.48
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-03 18:35 -03
Nmap scan report for 192.168.1.48
Host is up (0.00093s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
|_ vulners:
|_ vsftpd 3.0.3:
|_   CVE-2021-30047 7.5 https://vulners.com/cve/CVE-2021-30047
|_   CVE-2021-3618 7.4 https://vulners.com/cve/CVE-2021-3618
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ ftp syst.:
|_   STAT:
|_   FTP server status:
|_     Connected to ::ffff:192.168.1.43
|_     Logged in as ftp
|_     TYPE: ASCII
|_     No session bandwidth limit
|_     Session timeout in seconds is 300
|_     Control connection is plain text
|_     Data connections will be plain text
|_     At session startup, client count was 2
|_     vsFTPD 3.0.3 - secure, fast, stable
|_ _End of status
```

```
File Actions Edit View Help
kali@kali: ~
|_ 256 43:ca:a9:c9:31:7b:82:d9:03:ff:40:f2:a3:71:40:83 (ED25519)
80/tcp    open  http      Apache httpd 2.4.62 ((Debian))
|_ http-server-header: Apache/2.4.62 (Debian)
|_ http-csrf:
|_   Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.1.48
|_   Found the following possible CSRF vulnerabilities:
|_
|_     Path: http://192.168.1.48:80/apache2;repeatmerged=0
|_     Form id: wp-block-search__input-2
|_     Form action: http://localhost/
|_
|_     Path: http://192.168.1.48:80/manual
|_     Form id: wp-block-search__input-2
|_     Form action: http://localhost/
|_ http-title: Apache2 Debian Default Page: It works
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-robots.txt: 1 disallowed entry
|_ /wp-admin/
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-enum:
|_   /wp-login.php: Possible admin folder
|_   /wp-json: Possible admin folder
|_   /robots.txt: Robots file
|_   /readme.html: Wordpress version: 2
|_   /wp-includes/images/rss.png: Wordpress version 2.2 found.
|_   /wp-includes/js/jquery/suggest.js: Wordpress version 2.5 found.
|_   /wp-includes/images/blank.gif: Wordpress version 2.6 found.
```

```
File Actions Edit View Help
kali@kali: ~
|_ vulners:
|_   cpe:/a:openbsd:openssh:9.2p1:
|_     2C119FFA-ECE0-5E14-A4A4-354A2C38071A 10.0 https://vulners.com/githubexp
|_     loit/2C119FFA-ECE0-5E14-A4A4-354A2C38071A *EXPLOIT*
|_     CVE-2023-38408 9.8 https://vulners.com/cve/CVE-2023-38408
|_     CVE-2023-28531 9.8 https://vulners.com/cve/CVE-2023-28531
|_     B8190CDB-3EB9-5631-9828-8064A1575B23 9.8 https://vulners.com/githubexp
|_     loit/B8190CDB-3EB9-5631-9828-8064A1575B23 *EXPLOIT*
|_     8FC9C5AB-3968-5F3C-825E-E8DB5379A623 9.8 https://vulners.com/githubexp
|_     loit/8FC9C5AB-3968-5F3C-825E-E8DB5379A623 *EXPLOIT*
|_     8AD01159-548E-546E-AA87-2DE89F3927EC 9.8 https://vulners.com/githubexp
|_     loit/8AD01159-548E-546E-AA87-2DE89F3927EC *EXPLOIT*
|_     887EB570-27D3-11EE-ADBA-C80AA9043978 9.8 https://vulners.com/freebsd/8
|_     87EB570-27D3-11EE-ADBA-C80AA9043978
|_     5E6968B4-DBD6-57FA-BF6E-D9B2219DB27A 9.8 https://vulners.com/githubexp
|_     loit/5E6968B4-DBD6-57FA-BF6E-D9B2219DB27A *EXPLOIT*
|_     33D623F7-98E0-5F75-80FA-81AA666D1340 9.8 https://vulners.com/githubexp
|_     loit/33D623F7-98E0-5F75-80FA-81AA666D1340 *EXPLOIT*
|_     0221525F-07F5-5790-912D-F4B9E2D1B587 9.8 https://vulners.com/githubexp
|_     loit/0221525F-07F5-5790-912D-F4B9E2D1B587 *EXPLOIT*
|_     95499236-C9FE-56A6-9D7D-E943A24B633A 8.9 https://vulners.com/githubexp
|_     loit/95499236-C9FE-56A6-9D7D-E943A24B633A *EXPLOIT*
|_     PACKETSTORM:179290 8.1 https://vulners.com/packetstorm/PACKETSTORM:1
|_     79290 *EXPLOIT*
|_     FB2E9ED1-43D7-585C-A197-0D6628B20134 8.1 https://vulners.com/githubexp
|_     loit/FB2E9ED1-43D7-585C-A197-0D6628B20134 *EXPLOIT*
```


Detección y explotación de vulnerabilidades

- Se ejecutó ataque de fuerza bruta con John The Ripper para crakear las contraseñas de usuarios de la base de datos



```
kali@kali: ~  
File Actions Edit View Help  
GNU nano 8.3 hash.txt  
*6BB4837EB74329105EE4568DDA7DC67ED2CA2AD9  
*2470C0C06DEE42FD1618BB99005ADCA2EC9D1E19
```

```
debian@debian: ~  
File Actions Edit View Help  
Enter password:  
ERROR 1049 (42000): Unknown database '123456'  
debian@debian:~$ mysql -u root -p  
Enter password:  
Welcome to the MariaDB monitor. Commands end with ; or \g.  
Your MariaDB connection id is 49  
Server version: 10.11.6-MariaDB-0+deb12u1 Debian 12  
  
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.  
  
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement  
.  
  
MariaDB [(none)]> SELECT User, Password FROM mysql.user;  
+-----+-----+  
| User      | Password |  
+-----+-----+  
| mariadb.sys |          |  
| root      | *6BB4837EB74329105EE4568DDA7DC67ED2CA2AD9 |  
| mysql     | invalid  |  
| wordpressuser | *6BB4837EB74329105EE4568DDA7DC67ED2CA2AD9 |  
| user      | *2470C0C06DEE42FD1618BB99005ADCA2EC9D1E19 |  
+-----+-----+  
5 rows in set (0.048 sec)  
  
MariaDB [(none)]>
```

Detección y explotación de vulnerabilidades

- Se ejecutó ataque de fuerza bruta con John The Ripper para crackear las contraseñas de usuarios de la base de datos



```
(kali@kali)-[~]
$ john --format=mysql-sha1 hash.txt
Using default input encoding: UTF-8
Loaded 2 password hashes with no different salts (mysql-sha1, MySQL 4.1+ [SHA
1 128/128 SSE2 4x])
Remaining 1 password hash
Warning: no OpenMP support for this hash type, consider --fork=2
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
password (?)
1g 0:00:00:00 DONE 2/3 (2025-03-08 11:42) 11.11g/s 44.44p/s 44.44c/s 44.44C/s
123456 .. password1
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(kali@kali)-[~]
$ john --show hash.txt
?:123456
?:password

2 password hashes cracked, 0 left

(kali@kali)-[~]
```


Corrección de Debilidades

Devolver la seguridad

Un paso muy importante es tener copia de seguridad e ir corrigiendo actualizando, mitigando, explotando las vulnerabilidades encontradas, para que así se evite que un ataque escale y evitar o minimizar el daño.

```

debian@debian:/etc$ sudo nft list ruleset > /etc/nftables.conf
bash: /etc/nftables.conf: Permission denied
debian@debian:/etc$ sudo nft list ruleset | sudo tee /etc/nftables.conf
table inet filter {
    chain input {
        type filter hook input priority filter; policy drop;
        iif "lo" accept
        ct state { established, related } accept
        tcp dport 22 accept
        tcp dport 80 accept
        tcp dport 443 accept
        icmp type echo-request accept
        tcp dport 21 drop
    }

    chain forward {
        type filter hook forward priority filter; policy drop;
    }

    chain output {
        type filter hook output priority filter; policy accept;
    }
}
debian@debian:/etc$

```

```

debian@debian: /etc
File Edit View Search Terminal Help
GNU nano 7.2 vsftpd.conf *
# capabilities.
#
# Run standalone? vsftpd can run either from an inetd or as a standalone
# daemon started from an initscript.
listen=NO
#
# This directive enables listening on IPv6 sockets. By default, listening
# on the IPv6 "any" address (::) will accept connections from both IPv6
# and IPv4 clients. It is not necessary to listen on *both* IPv4 and IPv6
# sockets. If you want that (perhaps because you want to listen on specific
# addresses) then you must run two copies of vsftpd with two configuration
# files.
listen_ipv6=YES
#
# Allow anonymous FTP? (Disabled by default).
#anonymous_enable=YES
#
# Uncomment this to allow local users to log in.
local_enable=YES

```

AG Help AQ Write Out AW Where Is AK Cut AT Execute AC Location
 AX Exit AR Read File AL Replace AU Paste AJ Justify AV Go To Line

Corrección de Debilidades

```
debian@debian: /var/www/html
File Edit View Search Terminal Help
debian@debian: /var/www/html$ ls -l
total 248
-rwxrwxrwx 1 www-data www-data 10701 Sep 30 11:44 index.html
-rw-r--r-- 1 www-data www-data 405 Feb 6 2020 index.php
-rwxrwxrwx 1 www-data www-data 19915 Feb 21 12:51 license.txt
-rwxrwxrwx 1 www-data www-data 7409 Feb 21 12:51 readme.html
-rw-r--r-- 1 www-data www-data 7387 Feb 13 2024 wp-activate.php
drwxr-xr-x 9 www-data www-data 4096 Sep 10 2024 wp-admin
-rw-r--r-- 1 www-data www-data 351 Feb 6 2020 wp-blog-header.php
-rw-r--r-- 1 www-data www-data 2323 Jun 14 2023 wp-comments-post.php
-rw----- 1 www-data www-data 3024 Mar 8 17:33 wp-config.php
-rw-r--r-- 1 www-data www-data 3336 Feb 21 12:51 wp-config-sample.php
drwxr-xr-x 6 www-data www-data 4096 Mar 6 00:05 wp-content
-rw-r--r-- 1 www-data www-data 5617 Feb 21 12:51 wp-cron.php
drwxr-xr-x 30 www-data www-data 12288 Feb 21 12:51 wp-includes
-rw-r--r-- 1 www-data www-data 2502 Nov 26 2022 wp-links-opml.php
-rw-r--r-- 1 www-data www-data 3937 Mar 11 2024 wp-load.php
-rw-r--r-- 1 www-data www-data 51367 Feb 21 12:51 wp-login.php
-rw-r--r-- 1 www-data www-data 8543 Feb 21 12:51 wp-mail.php
-rw-r--r-- 1 www-data www-data 29032 Feb 21 12:51 wp-settings.php
-rw-r--r-- 1 www-data www-data 34385 Jun 19 2023 wp-signup.php
-rw-r--r-- 1 www-data www-data 5102 Feb 21 12:51 wp-trackback.php
-rw-r--r-- 1 www-data www-data 3246 Mar 2 2024 xmlrpc.php
debian@debian: /var/www/html$
```

```
debian@debian: /etc/apache2
File Edit View Search Terminal Help
GNU nano 7.2 apache2.conf *
# access here, or in any related virtual host.
<Directory />
    Options Indexes FollowSymLinks
    AllowOverride None
    Require all granted
</Directory>

<Directory /usr/share>
    AllowOverride None
    Options Indexes FollowSymLinks
    Require all granted
</Directory>

<Directory /var/www/>
    Options -Indexes +FollowSymLinks
    AllowOverride None
    Require all granted
</Directory>

#<Directory /srv/>

^G Help      ^O Write Out ^W Where Is  ^K Cut      ^T Execute  ^C Location
^X Exit      ^R Read File ^\ Replace   ^U Paste    ^J Justify  ^_ Go To Line
```


Corrección de Debilidades

```
tem
debian@debian: /
GNU nano 7.2 /etc/ssh/sshd_config *
#ListenAddress 0.0.0.0
#ListenAddress ::

#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key

# Ciphers and keying
#RekeyLimit default none

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:
#LoginGraceTime 2m
#PermitRootLogin no
#StrictModes yes
#MaxAuthTries 6

^G Help      ^O Write Out  ^W Where Is   ^K Cut        ^T Execute    ^C Location
^X Exit      ^R Read File  ^\ Replace    ^U Paste      ^J Justify    ^_ Go To Line
```

```
MariaDB [(none)]> ALTER USER 'root'@'localhost' IDENTIFIED BY 'Nueva1CON2seg..';
Query OK, 0 rows affected (0.020 sec)

MariaDB [(none)]> ALTER USER 'wordpressuser'@'localhost' IDENTIFIED BY '.conWORD7seg.';
Query OK, 0 rows affected (0.019 sec)

MariaDB [(none)]> FLUSH PRIVILEGES
-> EXIT
-> FLUSH PRIVILEGES;
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for the right syntax to use near 'EXIT FLUSH PRIVILEGES' at line 2
MariaDB [(none)]> FLUSH PRIVILEGES;
Query OK, 0 rows affected (0.018 sec)

MariaDB [(none)]> exit
```

```
MariaDB [(none)]> USE wordpress
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MariaDB [wordpress]> GRANT SELECT, INSERT, UPDATE, DELETE, CREATE, DROP, INDEX, ALTER, CREATE TEMPORARY TABLES, LOCK TABLES ON wordpress.* TO 'wordpressuser'@'localhost';
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for the right syntax to use near '* TO 'wordpressuser'@'localhost'' at line 1
MariaDB [wordpress]> GRANT SELECT, INSERT, UPDATE, DELETE, CREATE, DROP, INDEX, ALTER, CREATE TEMPORARY TABLES, LOCK TABLES ON wordpress.* TO 'wordpressuser'@'localhost';
Query OK, 0 rows affected (0.022 sec)

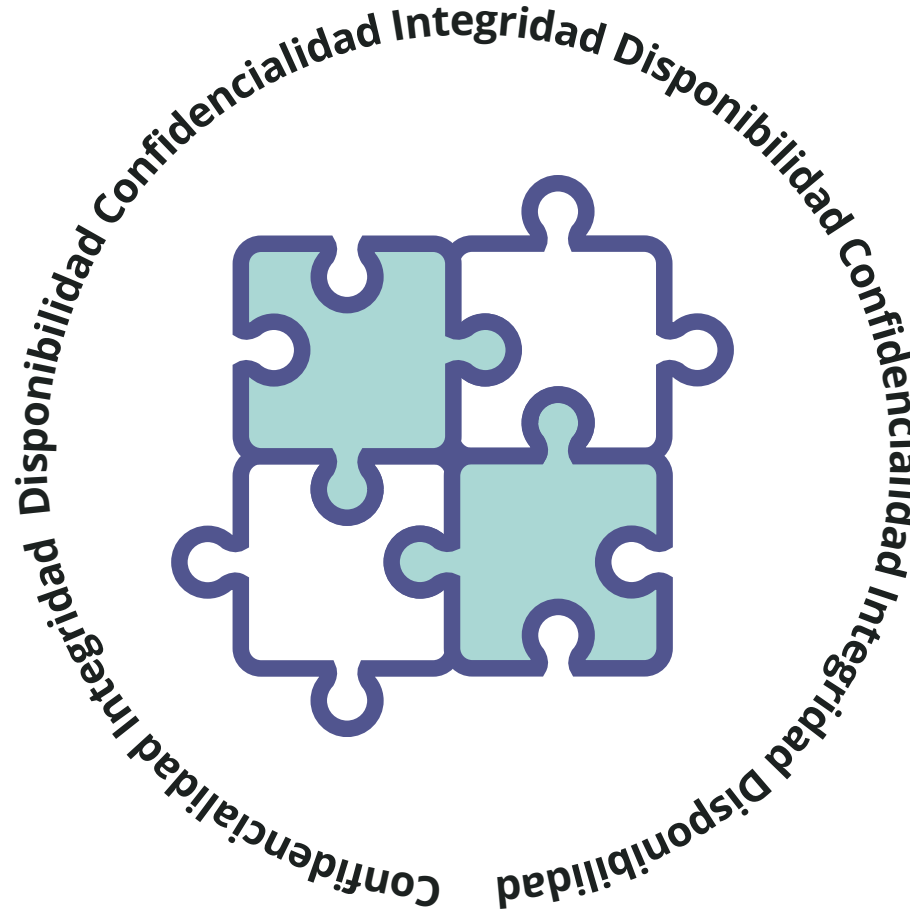
MariaDB [wordpress]> FLUSH PRIVILEGES;
Query OK, 0 rows affected (0.018 sec)

MariaDB [wordpress]>
```

CONCLUSIÓN

Este incidente de seguridad fue causado no por una si no por muchas vulnerabilidades y configuraciones erróneas, no se tiene medidas de protección ni herramientas que detecten algún ataque.

La ciberseguridad es como un rompecabezas ya que si falta alguna pieza se puede comprometer la seguridad de todo el sistema.



RECOMENDACIÓN

Se sugiere aplicar:

- Firewall (para protección y filtrar el tráfico)
- Waf (para proteger aplicaciones web)
- DLP (con esto se evalúa la información que es más valiosa para la organización, cuales son sus riesgos y así identificar y hacer una correcta configuración de usuarios sus permisos, etc.)
- IDS/IPS (pueden detectar eventos anómalos lo cual es esencial para poder mitigar algún evento).

Para ejecutar las herramientas se debe tener en cuenta que se debe actualizar servidores, aplicaciones y el sistema es decir realizar hardening para corregir vulnerabilidades, etc. También tener una revisión frecuente para verificar que las actualizaciones que se ejecutan automáticamente, se estén ejecutando correctamente.

También tener un plan de recuperación de incidentes para analizar lo ocurrido y mitigar eso y tal vez otras vulnerabilidades presente.

MUCHAS GRACIAS

PRESENTADO POR: YULYBETH RIOS